

MODULE 02

Security

Shielding Your

Agent

Telegram allowlist, UFW firewall, fail2ban and
secure credentials

DURATION

15 min

FORMAT

Live coding

KIT

2 files

MODULE 02 · SECURITY

Build Your AI COO

Why Now?

Real: 1,015+ Brute Force Attempts in 24h

Servers exposed on the internet receive THOUSANDS of attempted hacks per day.

If you don't shield yourself NOW, someone will get in.

Security is not optional. It is literally the difference between "my agent works" and "they hacked my server and stole my API keys".

What We Will Shield

Telegram Allowlist (dmPolicy)

Ensure that ONLY YOU can command the bot. If it is "open", anyone can use it.

1

UFW Firewall

Block ALL ports except SSH. Zero unnecessary exposure.

2

Fail2ban

Detect and ban IPs that attempt brute force on SSH (5 attempts · 1h ban).

3

Secure Credentials

NEVER hardcode API keys. Use 1Password CLI or environment variables.

4

Internal Ports

Gateway must listen on 127.0.0.1 (localhost), not 0.0.0.0 (entire world). Use Cloudflare Tunnel if you need external access.

5

Module 02 · Security

02

MODULE 02 · SECURITY

Build Your AI COO

Step 1: Configure Telegram Allowlist

This is the MOST IMPORTANT. If dmPolicy is "open", anyone who finds your bot can command it.

It should look like this:

..If It's "open"

Stop EVERYTHING and change to "allowlist" NOW. Every second that passes, someone could be using your agent.

How to get your Telegram ID?

Step 2: Configure UFW Firewall

UFW (Uncomplicated Firewall) is simple and powerful. Let's block EVERYTHING except SSH.

Check current config

```
cat ~/.openclaw/openclaw.json | grep dmPolicy
```

BASH

```
{  
  "telegram": {  
    "dmPolicy": "allowlist",  
    "dmAllowlist": ["123456789"]  
  }  
}
```

}

JSON

Send in the chat with your bot:

/start

The agent responds with your ID, like:

Your Telegram ID: 123456789

TEXT

Set default policy: BLOCK everything

```
sudo ufw default deny incoming
```

```
sudo ufw default allow outgoing
```

Allow SSH (otherwise you lock yourself out!)

```
sudo ufw allow ssh
```

Enable firewall

```
sudo ufw --force enable
```

BASH

·Result

Now ONLY the SSH port (22) is accessible. Everything else? Blocked.

Check status

sudo ufw status verbose

Module 02 · Security

03

MODULE 02 · SECURITY

Build Your AI COO

Step 3: Install and Configure Fail2ban

Fail2ban monitors logs and bans IPs that attempt brute force. Simple configuration: 5 failed SSH attempts · ban for 1 hour.

Configure the [sshd] section:

What this does:

maxretry = 5: Ban after 5 failed attempts

bantime = 3600: Ban lasts 1 hour (3600 seconds)

findtime = 600: 5 attempts in 10 minutes = ban

Install fail2ban

sudo apt update

sudo apt install fail2ban -y

Create local configuration

sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local

Edit config (or leave default)

sudo nano /etc/fail2ban/jail.local

BASH

[sshd]

enabled = true

port = ssh

filter = sshd

logpath = /var/log/auth.log

maxretry = 5

bantime = 3600

findtime = 600

INI

Restart fail2ban

sudo systemctl restart fail2ban

View status

sudo fail2ban-client status sshd

BASH

·Test Yourself

Try logging in with the wrong password 5x from another IP. You will see the ban happening in real time.

Module 02 · Security

04

MODULE 02 · SECURITY

Build Your AI COO

Step 4: Secure Credentials

NEVER hardcode API keys in config files. Use 1Password CLI or environment variables.

Option A: 1Password CLI (Recommended)

In the code, instead of:

Do:

Option B: Environment Variables

Install 1Password CLI

```
curl -sS https://downloads.1password.com/linux/keys/1password.asc | \
sudo gpg --dearmor --output /usr/share/keyrings/1password-archive-keyring.gpg
echo "deb [arch=amd64] https://downloads.1password.com/linux/debian/amd64 stable m
sudo tee /etc/apt/sources.list.d/1password.list
sudo apt update && sudo apt install 1password-cli -y
```

Login

```
op signin
```

```
BASH
```

```
const apiKey = "sk-ant-1234567890abcdef"; // BAD!
```

```
JAVASCRIPT
```

```
const apiKey = process.env.ANTHROPIC_API_KEY; // GOOD!
```

```
JAVASCRIPT
```

Edit .env

```
nano ~/.openclaw/.env
```

Add:

```
ANTHROPIC_API_KEY=sk-ant-1234567890abcdef
```

```
TELEGRAM_BOT_TOKEN=123456:ABC-defgh...
```

```
BASH
```

..CAUTION: systemd Override

If the gateway runs as a systemd service, the .service file may overwrite the .env file. Update BOTH when changing credentials.

Module 02 · Security

05

MODULE 02 · SECURITY

Build Your AI COO

Step 5: Application Ports

The OpenClaw gateway listens on port 18789 by default. NEVER expose this port to the entire world.

It should look like this:

If It's 0.0.0.0

This means that ANYONE on the internet can access the gateway. Change to 127.0.0.1 IMMEDIATELY.

What If I Need External Access?

Use Cloudflare Tunnel (free, secure, zero ports exposed).

See config

```
cat ~/.openclaw/openclaw.json | grep bindAddr
```

BASH

```
{  
  "gateway": {  
    "bindAddr": "127.0.0.1:18789"  
  }  
}
```

JSON

Install cloudflared

```
curl -L https://github.com/cloudflare/cloudflared/releases/latest/download/cloudfl
```

```
sudo dpkg -i cloudflared.deb
```

Create tunnel

```
cloudflared tunnel login
```

```
cloudflared tunnel create openclaw-gateway
```

```
cloudflared tunnel route dns openclaw-gateway gateway.yourdomain.com
```

BASH

·Result

Now you access via gateway.yourdomain.com · port 18789 is NEVER exposed directly.

Module 02 · Security

06

MODULE 02 · SECURITY

Build Your AI COO

Module 2 Checkpoint

dmPolicy = allowlist (only you command the bot)

UFW active (everything blocked except SSH)

Fail2ban protecting SSH (5 attempts · 1h ban)

Credentials in 1Password or .env (zero hardcoded)

Gateway on 127.0.0.1 (not 0.0.0.0)

· Prompt for the Agent

Paste this prompt into your OpenClaw chat after watching Module 2:

I just watched Module 2 of the security course. Read the security hardening PRD that I am attaching and guide me step by step. Important: - Before EACH action, explain WHAT you are going to do and WHY - Ask for confirmation before executing any change on the server - If something is already configured, let me know and skip to the next step - In the end, run a security audit and show me the result What I expect it to cover: 1.

Telegram allowlist (dmPolicy) · so no one commands my bot 2. UFW Firewall ·

block unnecessary ports 3. Fail2ban · protect against brute force SSH 4.

Credentials · how to securely store API keys 5. Application ports · don't expose

anything on 0.0.0.0 Let's shield my server?

·

NEXT MODULE

Module 3 · Identity: Giving Personality to the Agent

Module 02 · Security